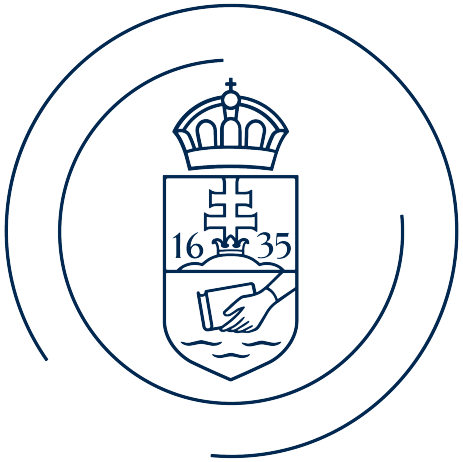


ELTE
EÖTVÖS LORÁND
UNIVERSITY

1010110100101010101110101101001010101011101110101101001010101000

Cybersecurity basics

Network security
Attacks, controls, technical details

Network Security

What you will learn...



- What assets are we trying to protect?
- What are the most common attack techniques?
- What are the most common defensive controls?
- How do firewalls work?
- What is the main difference between IDS and IPS?
- What is network segmentation and why is it useful?
- What are SIEM systems and how do they work?
- What are protocols used in network security?

The cybersecurity cube

- Network security focuses on the protection of data in transit.
- Network security is concerned with all three CIA data assets.
- Network security employs both human and process level controls, but focuses on technical controls.

Network attacks

Eavesdropping

When data in transit is read by an unauthorized party is called eavesdropping. This is an attack on confidentiality.

Man-in-the-middle

When data in transit can be altered by an unauthorized party is called main-in-the-middle. This is an attack on integrity.

Denial of service

When a network service is made unavailable by an attacker is called a denial of service attack or **DoS** attack. When such an attack utilizes a large number of attacking hosts (often unknown to them), we call this a distributed denial of service attack or **DDoS**.

Fundamental concepts of networking

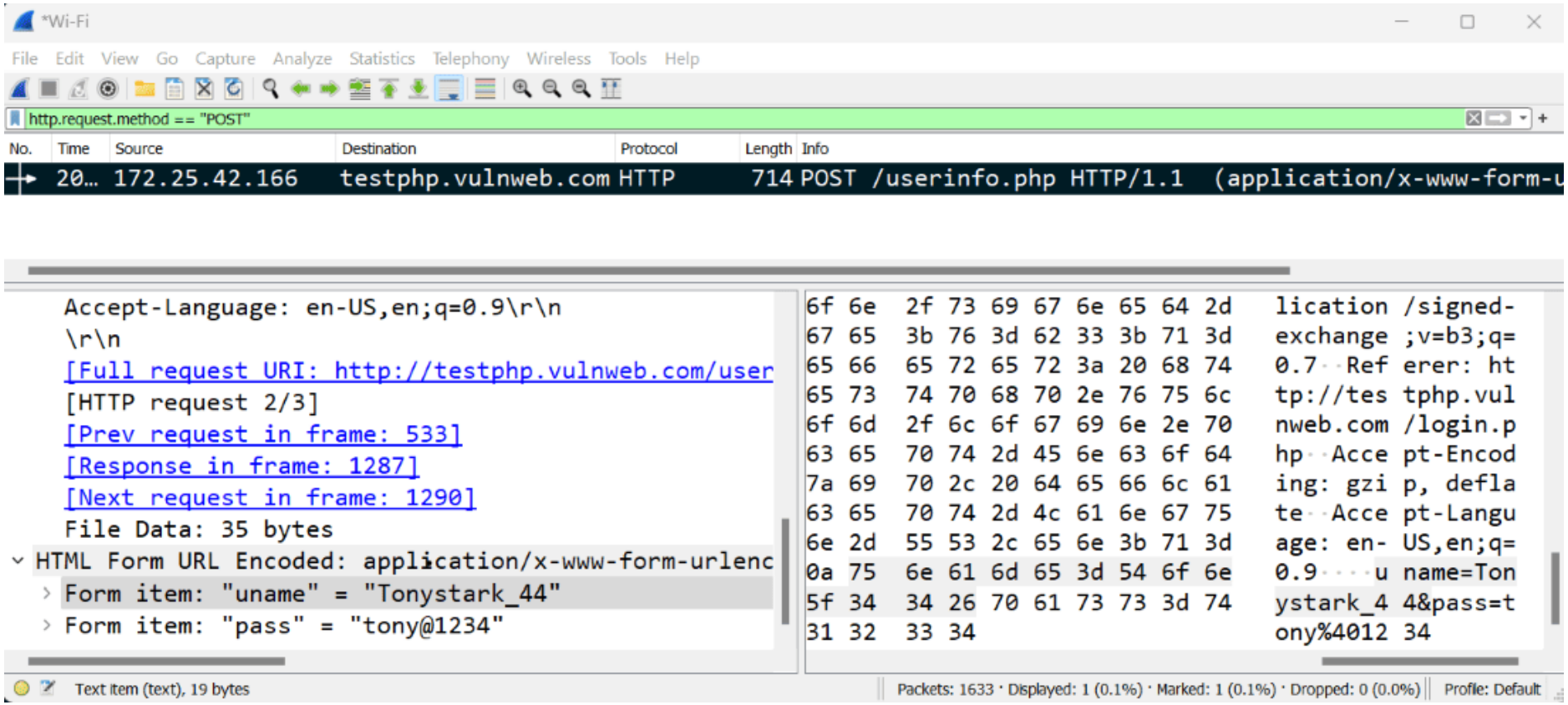
```
Tracing route to neptun.elte.hu [157.181.152.55]
over a maximum of 30 hops:

  1     2 ms     1 ms     3 ms  192.168.1.1
  2    23 ms     5 ms     4 ms  5.61.240.246
  3    20 ms    42 ms     7 ms  5.61.242.141
  4     6 ms     7 ms     6 ms  bix.rtr1.vh.hbone.hu [193.188.137.13]
  5     6 ms    27 ms    10 ms  hge0-0-0-0.core2.vh.hbone.hu [195.111.100.80]
  6    13 ms     5 ms     5 ms  hge0-0-0-0.rtr.elte.hbone.hu [195.111.100.46]
  7    37 ms     5 ms     5 ms  taurus.hbone-elte.backbone.elte.hu [157.181.141.13]
  8     5 ms     *       13 ms  fw.ext.backbone.elte.hu [192.153.18.113]
  9     8 ms    21 ms     7 ms  leo.fw-a.elte.hu [157.181.141.36]
 10     7 ms    10 ms    18 ms  centaur.leo-centaur.elte.hu [157.181.126.65]
 11     7 ms    17 ms    11 ms  mira.centaur-mira.elte.hu [157.181.126.134]
 12    30 ms    11 ms     8 ms  taurus.mira-taurus.elte.hu [157.181.126.29]
 13    33 ms    89 ms    17 ms  n9k1.taurus-n9k1.elte.hu [157.181.126.145]
 14     8 ms     5 ms     5 ms  gargamel.elte.hu [157.181.152.17]
```

Fundamental concepts of networking

- Every packet you send travels through dozens of different computers to reach its destination (10-15 in country, up to 30 internationally).
- Without additional controls, all of your data can be seen or even altered by the intermediary hops. They might outright deny continuing to forward your packets.
- Routes to your destination might change, even for the same destination.
- Do we blindly trust these potentially unknown computers?

Wireshark packet capture



Transport encryption

SSL/TLS

Transport Layer Security and its predecessor, Secure Socket Layer are protocols used to encrypt data traveling on the network. They utilize different cryptographic algorithms to make sure data is protected against eavesdropping and man-in-the-middle attacks (confidentiality and integrity). They also provide data authenticity by ensuring the identity of the server (authenticity).

SSL/TLS history

Protocol	Release Year	Applicability
SSL 1.0	Never released	Insecure, abandoned
SSL 2.0	1995	Obsolete, insecure
SSL 3.0	1996	Obsolete, vulnerable (POODLE attack)
TLS 1.0	1999	Deprecated (2021)
TLS 1.1	2006	Deprecated (2021)
TLS 1.2	2008	Widely used, secure
TLS 1.3	2018	Most secure, fastest

Table: SSL and TLS Versions

Authentication and authorization

- Recommended to have transport layer encryption, otherwise is not worth much.
- Authentication is the process of verifying **who** a user is.
- Authorization is the process of determining **what** a user can do.
- Let's consider the following scenario a baseline: we have sufficient encryption for data in transit, authentication and authorization.
- Let's take a look at some additional technical controls.

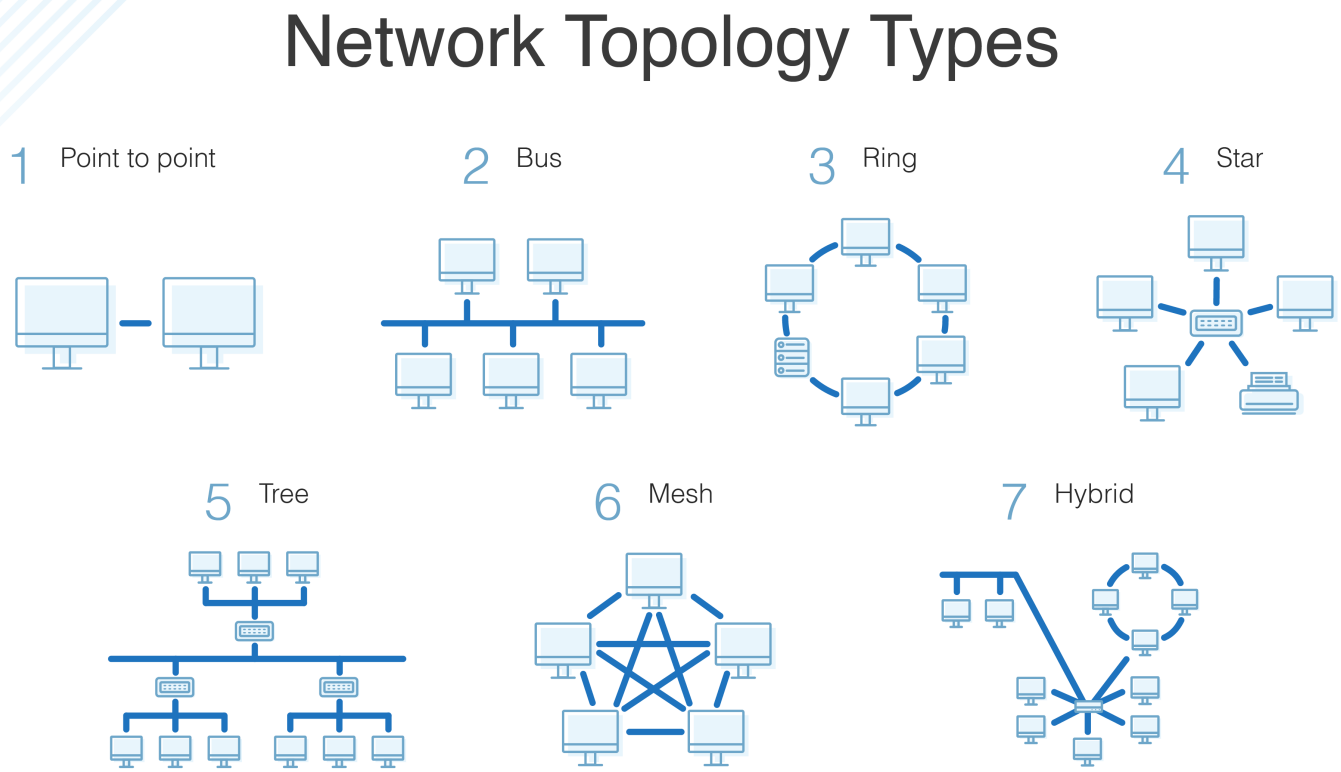
Network segmentation

Definition

Network segmentation involves dividing a larger network into smaller, isolated sub-networks (segments). Each segment can be isolated from others, typically using switches, routers, or firewalls.

- Segments can be created based on functionality, grouping hosts into one segment with similar needs.
- Segments can be created based on efficiency, creating a network layout where hosts that communicate with each other a lot are close.
- Segments can be created based on security needs, isolating critical systems from others.
- A network setup, where there is no isolation or segments is called a flat network and is generally undesirable from a security perspective.

Network topology



LAN (Local Area Network)

- A LAN is a network that connects devices within a limited geographical area, such as a home, office, or campus.
- Typically, LANs are fast, low-cost networks with high bandwidth (10 Mbps to 10 Gbps).
- Common LAN technologies: Ethernet, Wi-Fi.
- Devices in LAN: Computers, printers, switches, routers, etc.
- LANs enable resource sharing, such as file sharing, printers, and internet access.

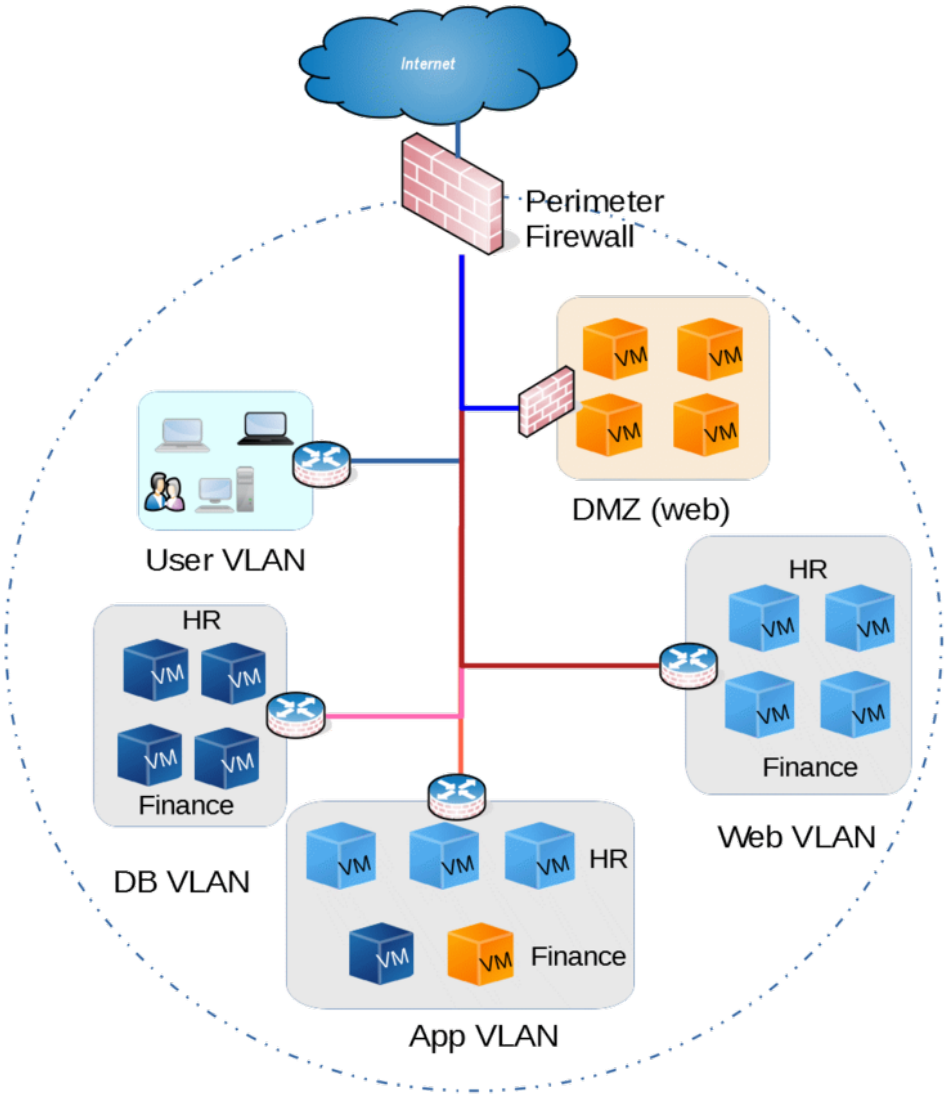
MAN (Metropolitan Area Network)

- A MAN covers a larger geographical area than a LAN, such as a city or a large campus.
- Typically used to connect multiple LANs within a city or large building complex.
- Common MAN technologies: Fiber optics, DSL, cable.
- MANs provide high-speed connections for city-wide communication and can be used by businesses.

WAN (Wide Area Network)

- A WAN is a network that covers a vast geographical area, such as a country or continent.
- WANs connect multiple LANs and MANs, allowing for communication over long distances.
- Common WAN technologies: MPLS, VPN, leased lines, satellite links.
- Bandwidth: Typically lower than LANs and MANs due to the large distances involved.
- WANs are used by large organizations, ISPs, and businesses to connect offices, data centers, and branch locations globally.

Network example



Data flow between segments

- Simple network devices like hubs just forward packets without any control or analysis.
- Slightly more sophisticated devices like switches might have more control such as creating VLANs. This means that a switch can control which devices are able to communicate with each other, even if physically they are connected to the device.
- In real life networks, segments are often connected via devices with even more capabilities than that.
- We can also consider the public internet to be a segment which devices connect to through some gateway.

What is TTL?

- TTL stands for Time to Live.
- A field in the IP header that indicates the maximum number of hops a packet can take before being discarded.
- Used to prevent packets from circulating indefinitely in case of routing loops.
- TTL is decremented by 1 each time a packet is forwarded by a router.

Time to Live

- TTL values can be used for information gathering.
- TTL values provide clues about the number of hops between source and destination.
- Attackers can use TTL to infer the network topology and locate potential targets.
- Information gathered from TTL values may reveal details about internal network structure.

TTL Reconnaissance Techniques

- Traceroute:
  - Traceroute utilizes TTL values to trace the path of packets through the network.
  - Each router along the path responds with an ICMP Time Exceeded message when TTL reaches 0.
- TTL Analysis:
  - Attackers analyze TTL values in response packets to identify devices' locations.
  - Can also identify the operating system (OS) based on TTL behavior.
  - Different operating systems set different TTL by default. Windows default is 128, Unix/MacOS is 64, while network devices such as Cisco often have default of 255.
  - If we send a packet to a host and get a response with TTL 125, we might infer that the target is a Windows host 3 hops away.

Firewalls

- Firewalls are network devices (physical or software) monitor and filter incoming and outgoing network traffic based on predefined security rules, allowing or blocking data based on IP addresses, ports, or protocols.
- Modern, stateful firewalls track the state of active connections, ensuring that packets are part of an established, valid session and not potential threats.
- Deep packet inspection firewalls have the capability to analyze the contents of packets to perform filtering.
- Firewalls log network activity and can send alerts for suspicious activities, providing real-time monitoring and support for incident response.

Firewall rules basics

- **Allow Rules:** These rules specify which traffic is permitted to pass through the firewall. If the incoming or outgoing traffic matches an allow rule, it is permitted to proceed.
- **Deny Rules:** These rules block specific traffic from passing through the firewall. If the traffic matches a deny rule, the firewall will drop or reject it.
- **Default Rule:** If no explicit rule is matched, firewalls often have a default policy, which could either be to deny all traffic or allow all traffic, depending on the configuration.

Firewall rule basics

Common examples in corporate infrastructure

- Rule: Allow, Source: 0.0.0.0/0 (Any), Destination: 192.168.56.23 (Web server), Port: 80, 443
- Rule: Allow, Source: 192.168.0.0/24 (Internal network), Destination: 192.168.1.2 (Internal DNS server), Port: 53
- Rule: Allow, Source: 192.168.56.30 (Web server), Destination: 192.168.56.40 (Database server), Port: 1433, 3306
- Rule: Deny, Source: 192.168.0.0/24 (Internal network), Destination: 129.134.0.0/17 (Facebook IP block), Port: Any
- Rule: Deny, Source: Any, Destination: 192.168.0.0/24 (Internal network), Port: Any

Virtual Private Networks

Definition: VPN

A Virtual Private Network (VPN) is a network architecture that enables secure, encrypted communication over a public or untrusted network (such as the internet) by creating a private, logical, and virtual tunnel between the user's device and a remote network or server. It achieves this by utilizing tunneling protocols and encryption methods to encapsulate and protect data traffic, ensuring confidentiality, integrity, and authenticity of data exchanged between endpoints.

In essence, VPNs use cryptographic algorithms to create a secure tunnel, simulating that you are physically connected to a remote network.

VPN tunnels

The core idea behind VPNs is being able to tunnel our network data to a remote network without worrying about it being intercepted or eavesdropped on. This is possible via a number of protocols such as:

- IPSec
- L2TP (Layer 2 tunneling protocol)
- SSL\TLS

IDS and IPS

Definition: IDS

IDS is a security system that monitors network or system activities for malicious activity or policy violations. It detects potential intrusions and alerts the system administrators.

Definition: IPS

IPS is similar to IDS but goes a step further by actively preventing or blocking malicious activities in real-time once detected.

Host based vs. Network Based

Both of these exist in two main forms: host-based (HIPS) or network-based (NIPS), which try to monitor either all traffic on a network or just focuses on an individual host.

Examples

Snort

A widely used open-source signature-based NIDS that monitors network traffic and logs suspicious activity. It can detect a variety of attacks, port scans, and other network-based threats.

Suricata

A high-performance open-source NIDS, HIDS, and IPS solution. It provides multi-threading capabilities and supports signature-based, anomaly-based, and protocol analysis methods.

NGFW (Palo Alto Networks Next-Generation Firewall)

Combines IPS with other security features, like application control and URL filtering, to prevent attacks in real-time by blocking malicious traffic before it reaches the network.

Security Information and Event Management

Definition: SIEM

SIEM is a comprehensive approach to cybersecurity that combines real-time monitoring, event management, and data analysis to detect, analyze, and respond to security incidents. SIEM systems aggregate, normalize, and analyze data from various sources such as network devices, servers, and security applications.

SIEM systems are more complex, sophisticated and are only used by larger organizations who have both the need to analyze large bodies of data and the resources to support such an undertaking.

Key features of SIEM

- **Real-time Monitoring**: Continuously collects and analyzes security events from different sources to identify threats quickly.
- **Event Correlation**: Links related events and alerts to identify patterns or attacks that may go unnoticed in individual logs.
- **Log Management**: Collects, stores, and organizes logs for compliance, forensic investigations, and analysis.
- **Incident Response**: Provides automated alerts and response tools to help security teams mitigate threats faster.
- **Reporting & Dashboards**: Offers visual dashboards and detailed reports for better understanding and tracking security events and trends.

Zero Trust Model

- **Principle:** "Never trust, always verify." Assume no user or device is inherently trustworthy, regardless of location (internal or external).
- **Key Components:**
  - **Verify Identity:** Continuously authenticate and authorize users, devices, and services.
  - **Least-Privilege Access:** Grant access based on role and minimize exposure to sensitive data.
  - **Micro-Segmentation:** Divide networks into smaller segments to limit the spread of potential breaches.
  - **Continuous Monitoring:** Real-time tracking of activities and behaviors to detect anomalies and respond to threats.
- **Assume Breach:** Focus on minimizing damage and containing threats quickly, as breaches are inevitable.